Saudi GRC Platform

Rbac Matrix

Source: `rbac-matrix.md`

09 — Role-Based Access Control Matrix

Spring Security RBAC: roles + permissions backed by `iam.roles` + `iam.role_permissions` + `iam.user_roles`. Permission grain is `{MODULE}:{ACTION}` e.g. `RISK:READ`, `CYBER:WRITE`.

Method-level guard: `@PreAuthorize("hasPermission('MODULE','ACTION')")` delegating to `ModulePermissionEvaluator`. UI gating uses `hasAnyRole(...)` helper from `lib/auth.ts`.

Legend (action columns): - **V** view / read - **C** create - **E** edit - **A** approve / sign - **D** delete / archive - **X** export - **S** digital signature - **R** run report

Role	Modules	V	C	E	A	D	X	S	R
System Administrator	All (platform-wide)	✓	✓	✓	✓	✓	✓	—	✓
GRC Administrator	Platform-config + Workflow + Notifications	✓	✓	✓	✓	✓	✓	—	✓
Risk Manager	ERM, Compliance, Reporting	✓	✓	✓	✓	own	✓	✓	✓
Risk Owner	ERM (own risks), CAPA	✓	✓	own	—	own	own	—	own
Control Owner	Compliance, Cyber, Evidence	✓	✓	own	—	own	own	—	own
Evidence Owner	Evidence	✓	✓	own	own	own	own	own	own
BCM Manager	BCM (all), ERM-link	✓	✓	✓	✓	✓	✓	✓	✓
BIA Owner	BCM (BIA), Critical Services	✓	✓	own	—	own	own	—	own
Service Owner	BCM (own services), BIA	✓	own	own	—	—	own	—	own
DR Owner	BCM (DR plans + tests)	✓	✓	own	own	own	own	✓	own
Crisis Manager	BCM (crisis), Incident, Comms	✓	✓	✓	✓	—	✓	✓	✓

Role	Modules	V	C	E	A	D	X	S	R
Supplier Manager	SCM, TPRM	✓	✓	✓	own	✓	✓	—	✓
Procurement Owner	SCM (own vendors), Contracts	✓	✓	own	—	own	own	—	own
Cybersecurity Manager / CISO	Cyber, Incident, NCA, TPRM-cyber	✓	✓	✓	✓	✓	✓	✓	✓
NCA Compliance Owner	Cyber, Compliance, NCA filing	✓	✓	✓	✓	own	✓	✓	✓
Asset Owner	Cyber (own assets)	✓	✓	own	—	own	own	—	own
Vulnerability Manager	Cyber (vulns), CAPA	✓	✓	✓	own	own	✓	—	✓
Data Protection Officer (DPO)	Privacy (all), PDPL workflows	✓	✓	✓	✓	own	✓	✓	✓
Privacy Manager	Privacy, DSR, PIA, breach	✓	✓	✓	✓	own	✓	✓	✓
Data Owner	Privacy (own data), Disposal	✓	own	own	—	own	own	—	own
Legal Reviewer	Compliance, Privacy (DSA, contracts)	✓	—	review	✓	—	own	✓	own
Compliance Officer	Compliance (all), Reporting	✓	✓	✓	✓	own	✓	✓	✓
Internal Auditor	All (read-only) + Audit module	✓	own (audit only)	own (audit)	—	—	✓	—	✓
Executive Reviewer	Dashboards, Reports, sign-off	✓	—	—	sign	—	✓	✓	✓

Role	Modules	V	C	E	A	D	X	S	R
Board Secretary	Board Pack, Committee, Reporting	✓	✓	✓	✓	—	✓	✓	✓
External Auditor	All (read-only) for engagement window	✓	—	—	—	—	✓	—	✓
Supplier User	Vendor Portal (own vendor only)	own	own (questionnaire)	own	—	—	—	—	—
Vendor Risk Manager	SCM, TPRM, Fourth-party	✓	✓	✓	✓	own	✓	✓	✓

Module-level access summary

The matrix above expressed per module:

Module	Read	Write	Approve	Sign
ERM	RM, RO, all read-only roles	RM, RO	RM	CRO, Executive
BCM	BCM Mgr, BIA Owner, Svc Owner, DR Owner, Crisis Mgr	BCM Mgr, DR Owner	BCM Mgr	CIO, Exec
SCM	Supplier Mgr, Procurement, Vendor Risk Mgr	Supplier Mgr	Vendor Risk Mgr	COO
Cyber	CISO, NCA Compliance Owner, Asset Owner, Vuln Mgr	CISO, Vuln Mgr	CISO	CISO
Privacy	DPO, Privacy Mgr, Data Owner	DPO, Privacy Mgr	DPO	DPO + CISO
Compliance	Compliance Officer, Legal	Compliance Officer	Compliance Officer	Exec
Evidence	Evidence Owner, Auditors	Evidence Owner	Evidence Owner	Auditor (chain)
Incident	Incident Mgr, CISO, Crisis Mgr	Incident Mgr	CISO	CISO + DPO
TPRM	Vendor Risk Mgr, CISO, Procurement	Vendor Risk Mgr	CISO	CISO
Reporting	All execs, Auditors	Board Sec	Board Sec	Chair
Admin / Workflow	System Admin, GRC Admin	System Admin, GRC Admin	System Admin	n/a

Special access patterns

1. **Tenant scope.** Every permission check is filtered by `organisationId`. Users with `PLATFORM_ADMIN` can switch tenants via the org-switcher in the topbar.
2. **Own-record scoping.** Roles with "own" in the matrix can only read/ write records where `owner_user_id = currentUserId()` or where the record is in their direct-report tree.
3. **Auditor windows.** External auditors get a time-bound role `EXTERNAL_AUDITOR` valid only for the engagement window.
4. **Vendor portal.** A vendor user's session is bound to a single `vendor_id`; they cannot enumerate other vendors.
5. **Break-glass.** A `BREAK_GLASS` permission grants temporary `PLATFORM_ADMIN`-like access; every use writes a special audit event and a Slack/Teams alert to the SOC.
6. **MFA enforcement.** Approve / sign actions require MFA satisfied within the last 15 minutes; otherwise re-prompt.

Seeded users (dev profile only)

Username	Password	Role
admin	Admin@12345	PLATFORM_ADMIN
riskmanager	Risk@12345	RISK_MANAGER
auditor	Audit@12345	AUDITOR

These accounts must be disabled in prod.